

# Application Architecture

Purple Team Test Platform

Proposal for a dedicated, isolated, and auditable environment for controlled purple-team testing.

By: Colin Tarkington – Cyber  
Operations Intern

# Overview and Business Objectives

**Problem being solved:** provide a controlled purple-teaming toolset environment without mixing offensive tools with user workstations.

**Business value:** improves purple-team testing, detection validation, security research, and auditability while reducing blast radius.

**Implementation approach:** dedicated physical Windows host running Hyper-V with one standalone, non-domain joined Kali Linux VM.

**Primary users:** approved Cybersecurity / Purple Team users only; no broad or general-purpose access.

**Target scope:** internal security lab environment with a reserved static IP for host and default-deny firewall posture.

**AI / Shaw proprietary data:** no AI component proposed; no PII, purchasing, or production business data storage is intended.

**Enterprise impact:** limited-scope security capability with architecture controls for EA, Cybersecurity, IAM, Network, and Operations review.

# Additional Architecture Review Questions

**Fusion / ERP:** not part of Shaw Fusion ERP; this is a Cybersecurity lab and detection-validation environment.

**Oracle / business application comparison:** not applicable; this proposal is infrastructure and security tooling, not an ERP or commercial application replacement.

**Cloud-first / native:** primary proposal is on-premises dedicated physical host for isolation and local control; GSA provides the preferred remote-access path.

**Buy before build / SaaS / PaaS / Kubernetes:** not applicable to Kali lab execution; existing enterprise controls are reused where appropriate.

**Existing standards:** aligns to dedicated asset ownership, network segmentation, default-deny firewalling, MFA, PAM/Password Safe, and centralized logging.

**Availability / continuity:** limited operational dependency; rebuild/snapshot process and documented ownership are recommended for hygiene and recoverability.

**Performance:** 4+ CPU cores, 32GB RAM, 1 TB NVMe host; Kali allocation of 4–8 vCPUs, 16–32 GB RAM, and 250–500 GB disk.

**Latency:** remote access should be usable through GSA + RDP for administrative and purple-team work; no high-volume production transaction workload is proposed.

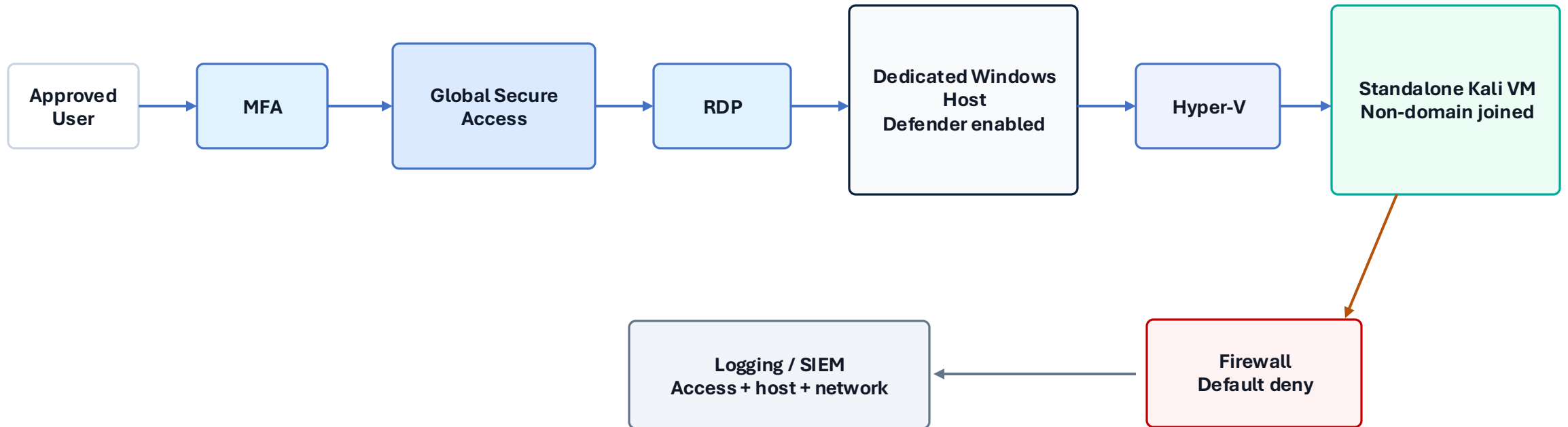
# Application Components

| Component      | Details                                                                |
|----------------|------------------------------------------------------------------------|
| Solution Type  | Security lab / purple-team sandbox                                     |
| Physical Host  | Dedicated Windows 11 Enterprise host                                   |
| Virtualization | Hyper-V; single virtualization layer                                   |
| Primary VM     | Kali Linux VM, standalone / non-domain joined                          |
| Host Specs     | 4 CPU cores; 32 GB RAM; 1 TB NVMe SSD                                  |
| VM Allocation  | 4 vCPUs; 16 GB RAM; 250–500 GB disk                                    |
| Network        | Standard corporate network connection with reserved/static IP for host |
| Firewall       | Default-deny; approved traffic by exception                            |

| Component           | Details                                         |
|---------------------|-------------------------------------------------|
| Remote Access       | GSA + MFA + RDP to Windows host                 |
| Fallback Access     | Bastion-style access if GSA is not feasible     |
| Authentication      | Approved users; local Kali accounts only        |
| Credential Handling | Approved Password Safe / PAM process            |
| Endpoint Protection | Defender on host; Kali excluded by design       |
| Logging             | Access, host, VM, firewall, file transfer, SIEM |
| File Transfer       | RDP clipboard / drag-drop; SFTP secondary       |
| Asset ID            | Dedicated hostname, VM name, and reserved IPs   |

# Logical Architecture

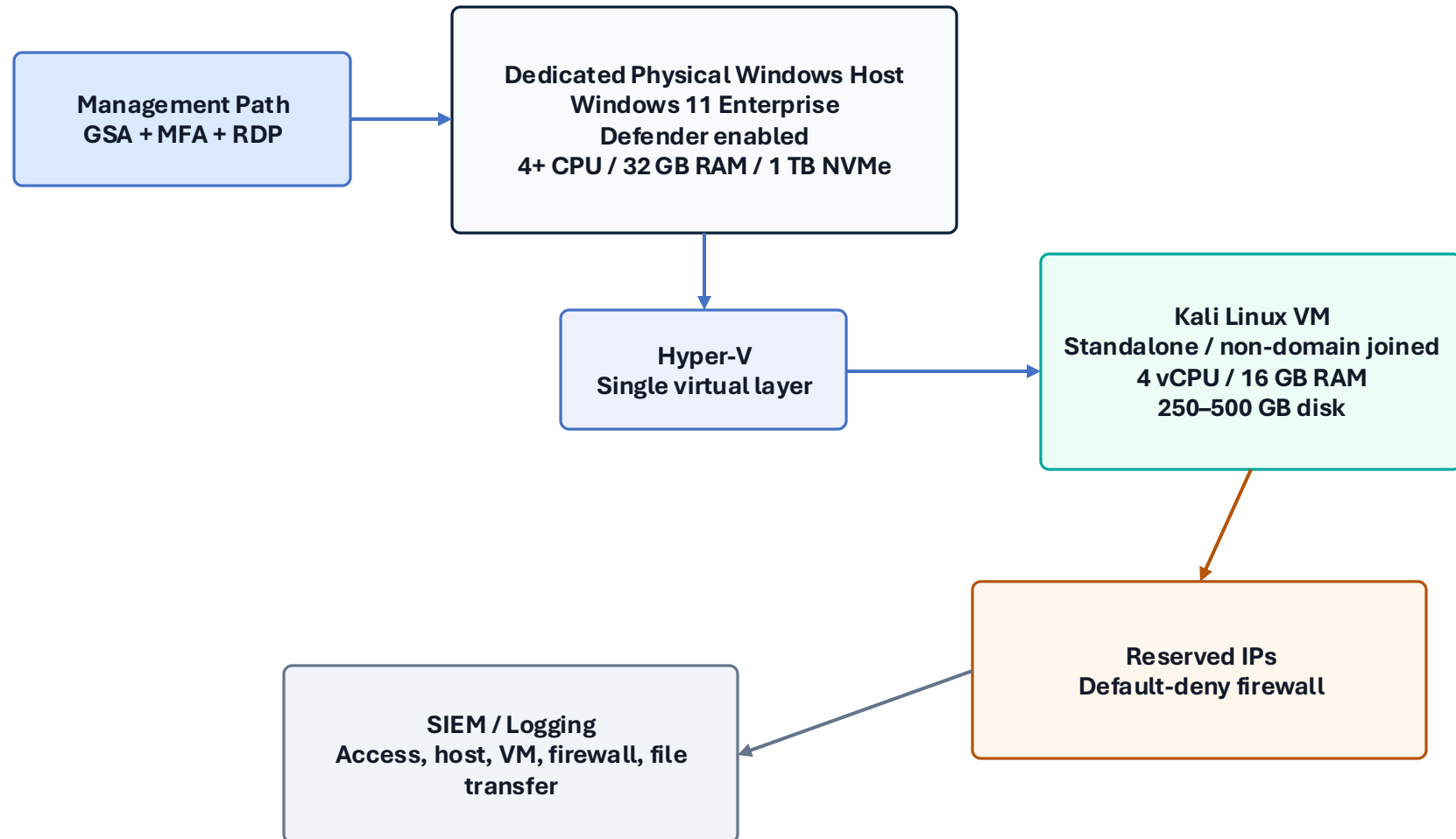
Key logical boundary: no broad/direct production-network access; approved traffic only by exception.



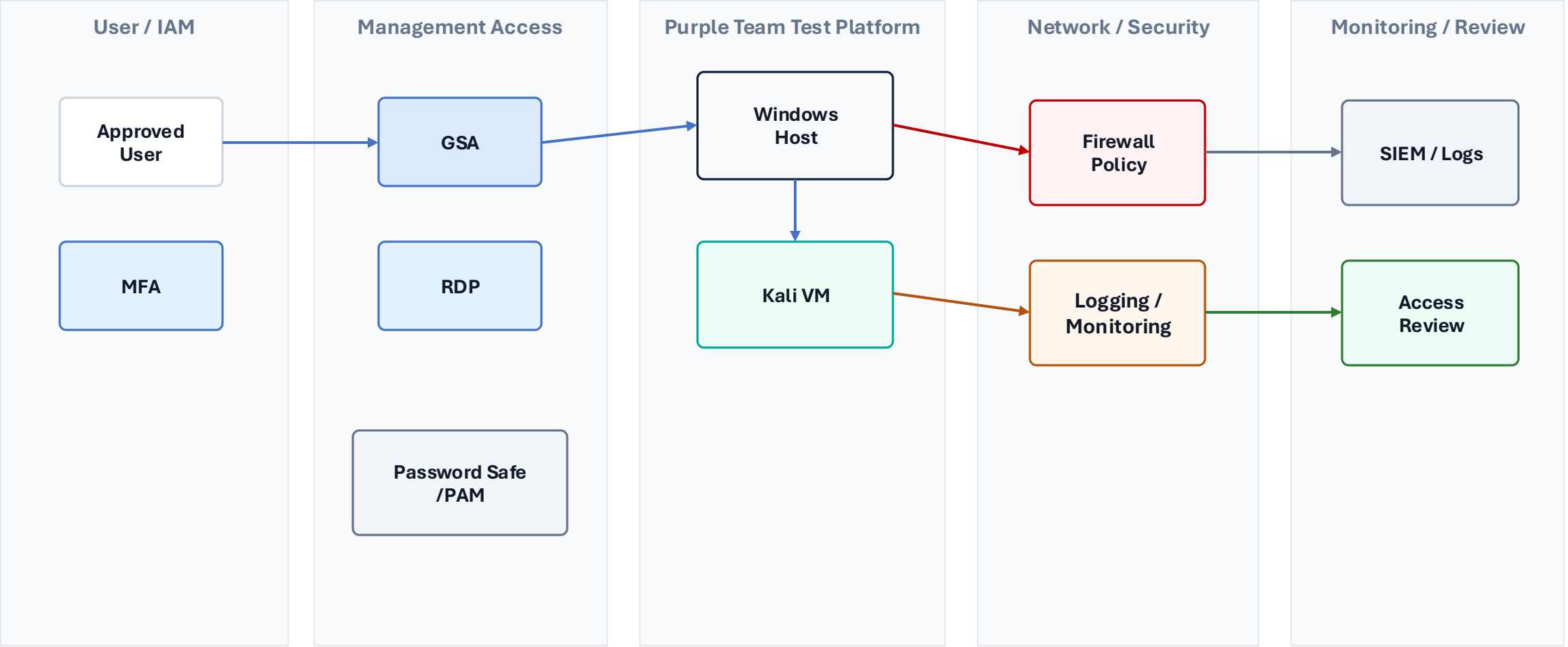
# Deployment Diagram Sandbox

Environments / Functions:

- Dedicated Host – physical Windows host
- Sandbox – isolated Kali VM segment
- Management – GSA/MFA/RDP path
- Monitoring – firewall and SIEM logging



# Integration



# Data Flows

## Access Flow

- User authenticates with MFA
- GSA brokers access to RDP
- RDP terminates on dedicated Windows host
- User operates Kali VM through controlled session

## Logging Flow

- Access attempts and host authentication logs
- VM start/stop and configuration changes
- Firewall allow/block events
- Forward key logs to SIEM where available

## File Transfer Flow

- Approved small files via RDP clipboard / drag-and-drop
- SFTP only for larger or repeatable files/logs
- Avoid FTP, personal cloud storage, and unmanaged shared drives
- No malware samples or unmanaged payload movement

## Network/Test Traffic Flow

- Default-deny outbound and inbound
- Approved test targets, ports, updates, and logging destinations only
- Ability to disconnect/disable when not in use

# Dependencies

**Infrastructure:** dedicated physical Windows host, Hyper-V availability, host lifecycle support, and asset inventory records.

**Network:** reserved IPs, default-deny firewall rules, approved test-target ranges, and ability to disconnect/disable access.

**IAM / Access:** approved user list, MFA-protected access path, periodic access reviews, and Password Safe / PAM credential workflow.

**Cybersecurity Operations:** Defender monitoring on host, logging review, SIEM integration where available, and alerting for unexpected access or traffic.

**Endpoint / Platform Operations:** OS updates, host hardening, approved Defender exclusions only if required for VM storage paths, and VM rebuild/snapshot hygiene.

**Enterprise Architecture:** review of scope boundary, ownership model, operational risk controls, diagrams, and documentation package.

**File Transfer Controls:** RDP clipboard / drag-drop as primary approved method and SFTP as secondary; FTP and unmanaged repositories avoided unless specifically approved.

# Security and Compliance

Dedicated physical Windows host to reduce blast radius and keep offensive tools separate from user workstations and shared production systems.

Standalone, non-domain joined Kali VM with local accounts only; no corporate identity dependency inside Kali.

GSA + MFA + RDP is the preferred access path; no direct RDP.

Default-deny inbound and outbound firewall posture; approve updates, logging, management, and test-target traffic only by exception.

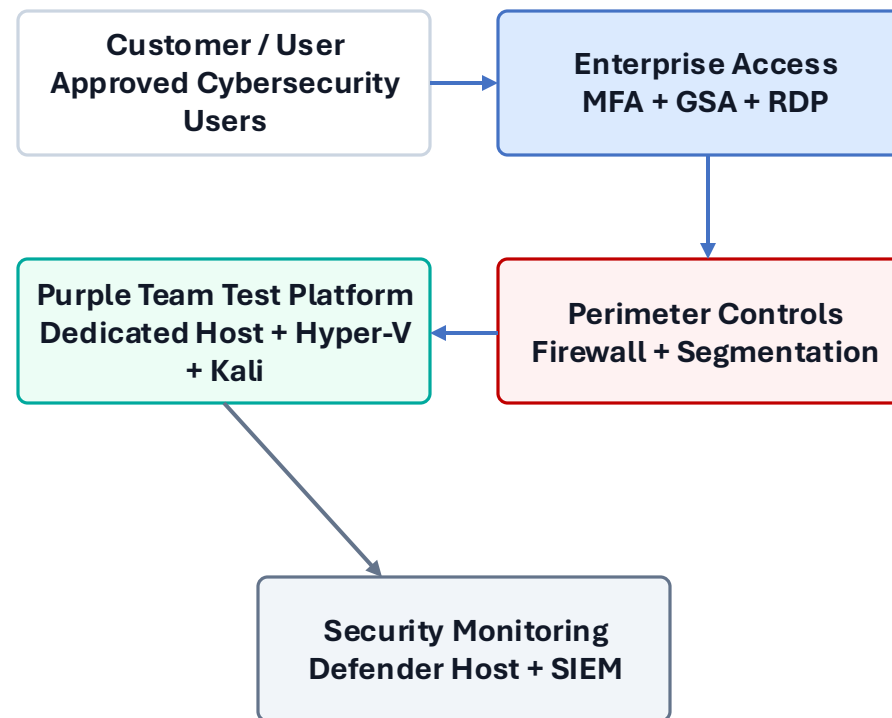
Credentials managed through the approved Password Safe / PAM process; no reusable shared passwords or credentials stored in documents, Teams, or scripts.

Defender remains enabled on the Windows host; Kali does not run Defender by default to preserve approved tool functionality.

Defender exclusions only for approved VM storage paths if required; document and approve any exclusions.

Centralize access, host, firewall, approved file transfer, and key Kali logs for monitoring and auditability.

Scope boundary: not a malware detonation, live malware storage, unknown payload execution, or reverse-engineering environment.



# Authentication and Authorization

**Authentication path:** approved user → MFA → Global Secure Access → RDP → dedicated Windows host → Kali VM.

**Authorization scope:** approved Cybersecurity / Purple Team users only; no broad or general-purpose access.

**Kali identity:** standalone VM, non-domain joined, local accounts only, and no dependency on corporate domain authentication.

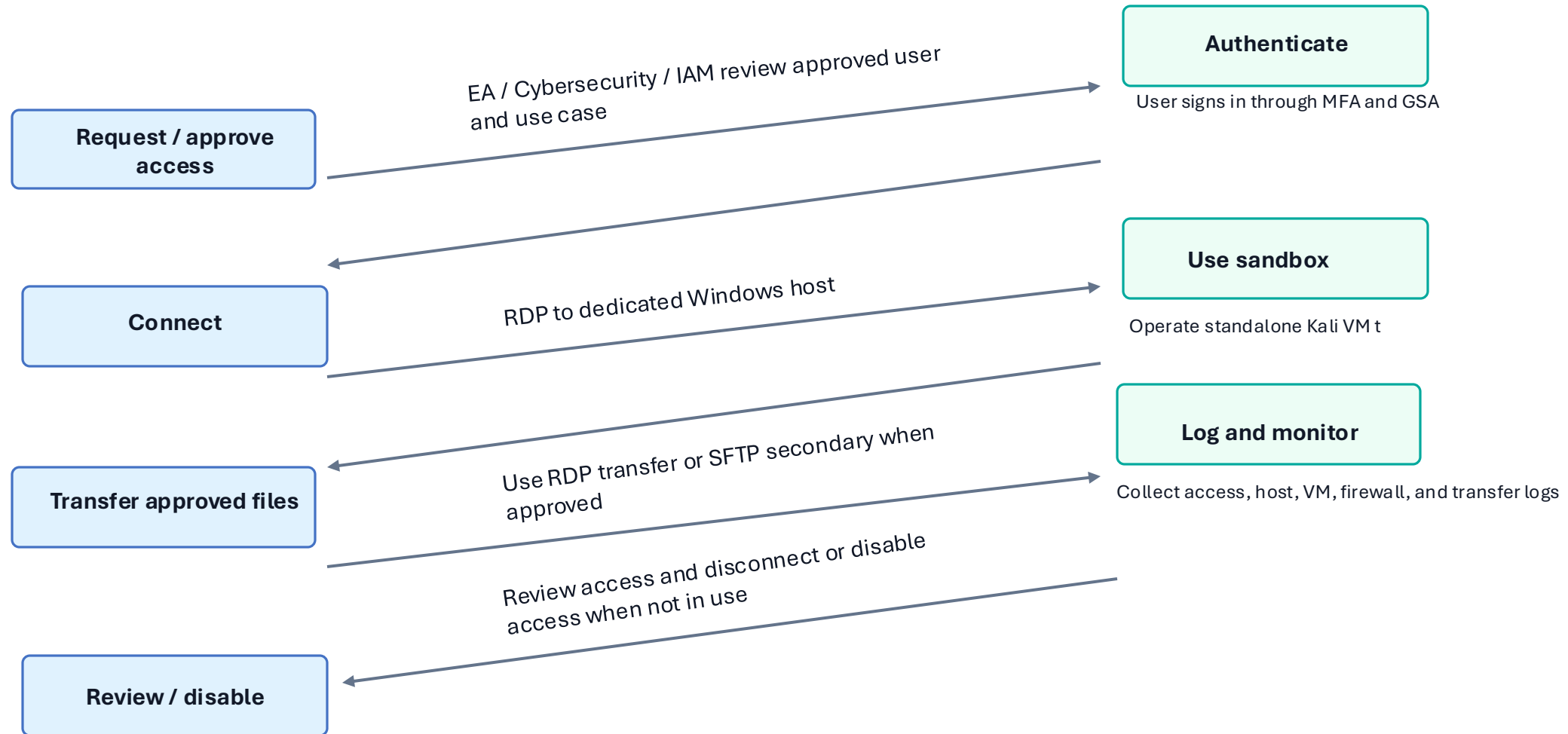
**Credential handling:** all credentials managed through approved Password Safe / PAM process.

**Credential restrictions:** no reusable shared passwords; no credentials stored in documents, Teams messages, or scripts.

**Governance:** named ownership for host and VM, periodic access review, and auditable credential use.

**Fallback:** Bastion-style access may be considered if GSA is not feasible, with equivalent MFA and logging expectations.

# Activity Diagram



# Support Lifecycle

**Application and infrastructure ownership:** assign named owners for the dedicated Windows host, Hyper-V configuration, Kali VM, network segment, and access controls.

**Software installation:** Kali tooling installed only for approved purple-team testing and detection-validation use cases.

**Licensing:** Windows host and any required enterprise tooling should follow standard corporate licensing and asset-management processes.

**Operating system upgrades:** Windows host should remain supported and patched; Kali VM should follow a controlled update, rebuild, or snapshot hygiene process.

**System administration:** limited to approved administrators; administrative activity should be logged and reviewable.

**Vulnerability scanning and response:** host remains monitored as a corporate asset; any approved exceptions should be documented.

**Documentation:** maintain architecture diagrams, hardware specs, IP/hostname records, firewall rules, access list, and support runbook.

**Data retention:** retain access, host, firewall, and SIEM logs according to applicable enterprise retention standards.

# Example Support Lifecycle Statements

**Application Portfolio / Asset Inventory:** The Kali Purple Team Test Platform should be registered as a dedicated Cybersecurity lab capability with the appropriate host, VM, hostname, IP, owner, location, and support details.

**Software Maintenance:** Cybersecurity Operations, with Infrastructure and Endpoint support as needed, should maintain the host, Hyper-V platform, Kali VM, approved tooling, and documented configuration over the life of the solution.

**Access Reviews:** Approved users should be reviewed periodically. Access should be limited to Cybersecurity / Purple Team use cases and removed when no longer required.

**Vulnerabilities and Exceptions:** The Windows host should remain Defender-monitored and patched. Any exclusions for approved VM storage paths should be documented and approved before implementation.

**Code / Tooling Reviews:** Offensive tools and test use cases should remain purpose-bound to detection validation, authorized testing, and security research; this environment is not a malware detonation sandbox.

**Documentation:** EA-ready documentation should include logical/deployment architecture, access flow, data flows, security controls, dependencies, and support lifecycle details.

**Recoverability:** The Kali VM should use a controlled rebuild/snapshot process to keep the sandbox clean and recoverable after authorized testing activity.